Cheatsheet AZ-104 — 02 · RBAC: built-in roles, scopes, inheritance and interpreting assignments

1. The three pieces of an assignment

Piece	What it is	Exam details
Security principal	User, **group** (transitive nesting), service principal or managed identity	Prefer assigning to groups. Guests also receive roles. A principal can hold several assignments at once
Role definition	Collection of permissions in JSON: `Actions`, `NotActions`, `DataActions`, `NotDataActions`, `AssignableScopes`	`NotActions` **subtracts** permissions within the same role; **it is not a deny**: another role can grant the action again
Scope	Management group → subscription → resource group → resource	**Inherited** downwards. The effective result is the **union** of all assignments (the most permissive wins). Only **deny assignments** (deployment stacks / managed apps; not created by hand) subtract

- Limits: **5,000** assignments per subscription, **500** per management group, **5,000** custom roles per tenant.
- A new assignment can take **a few minutes** to apply (up to 10, more if the token is cached). Every change is recorded in the **Activity log** (Microsoft.Authorization/roleAssignments/write).
- RBAC governs the **control plane** (`management.azure.com`). The data plane (blobs, queues, Key Vault in RBAC mode) requires roles with **DataActions**, or else keys / SAS.
- Optional: **ABAC condition** (blob and queue data roles, and to delegate role assignments with the RBAC Administrator), description, and **eligible** assignments with PIM for Azure resources (P2).

2. Built-in roles you must tell apart

Role	Can	Cannot	Signal
Owner	Everything, including **assigning roles** and managing **locks**	—	"full access including access management"
Contributor	Create and manage any resource	Assign roles, create or delete locks, elevate access (NotActions `Microsoft.Authorization/*/Write`)	"manage everything except access"
Reader	View resources	Change anything; cannot **list storage keys** either (it is a POST)	"view only"
User Access Administrator	Manage access (assignments) and locks	Manage resources	"manage user access to resources"
Role Based Access Control Administrator	Assign roles only (ideal for delegating with conditions)	Nothing else; neither locks nor resources	"assign roles, nothing else, least privilege"
Virtual Machine Contributor	Create, start, stop, resize and delete VMs and disks; create NICs and join them to subnets	Create VNets or NSGs, manage the storage account, assign access, sign in to the VM	"manage VMs but not the network they connect to"
Network Contributor	All networking (VNet, NSG, LB, PIP)	Nothing outside Microsoft.Network	"manage networking only"
Storage Account Contributor	Manage accounts and **list keys**	Read data with an Entra identity	"manage storage accounts"
Storage Blob Data Owner / Contributor / Reader	Blob data via Entra (data plane)	Manage the account	"access blobs with Entra ID"
Storage Account Key Operator Service Role	List and **regenerate** keys	Nothing else	"rotate keys, least privilege"
Security Admin / Security Reader	Defender for Cloud, security policies	Manage resources	"security recommendations"
Monitoring Contributor / Reader · Log Analytics Contributor / Reader	Alerts, diagnostic settings, workspaces and queries	Other resources	"configure alerts", "query logs"
Backup Contributor / Operator / Reader	Manage backups in the vault (Operator: no deleting)	Create the vault (Contributor can)	"manage backups"
Website Contributor · Web Plan Contributor	Web apps · App Service plans	The other one	"manage the web app only"
Key Vault Administrator · Key Vault Secrets User	The entire Key Vault data plane (RBAC mode) · read secrets	Manage the vault (control plane)	"read secrets, least privilege" → Secrets User
Managed Identity Operator / Contributor	Assign a user-assigned MI to resources · create it	—	"assign the identity to the VM"
Resource Policy Contributor	Create and assign Azure Policy	Assign roles	"manage policies"
Management Group Contributor / Reader	Manage or read management groups	Resources	"create management groups"
Cost Management Reader / Contributor · Billing Reader	View costs and budgets · create budgets · invoices	Resources	"auditors review costs"
Tag Contributor	Tag any resource (via PowerShell / API)	Modify the resource	"add tags without modifying resources"
Virtual Machine Administrator Login / User Login	Sign in to the VM with Entra ID (admin / user)	Manage the VM (that is VM Contributor)	"sign in to the VM with Entra credentials"

Classic administrators (Service Administrator, Co-Administrator) have been **retired** since August 2024: if they appear in a question, the correct answer is always an RBAC role.

3. Interpreting assignments

Assignments	Result	Why
Reader on the subscription + Contributor on RG1	Contributor on RG1, Reader on the rest	Union; the more specific scope does not "downgrade", it adds
Owner on the management group (via group) + explicit Reader on the subscription	**Owner** on the whole subscription	There is no "most restrictive assignment" concept; only deny assignments subtract
Contributor on the subscription	Creates everything, but does **not** assign roles or create locks	NotActions on Microsoft.Authorization
Reader on a storage account	Sees the account; sees neither keys nor blobs	listKeys is an action; blobs are data plane
Owner on the subscription, portal with "Switch to Entra ID user account"	Cannot read blobs; can with "Access key"	Owner has no DataActions
Virtual Machine Contributor on RG1	Starts, stops, deletes and resizes VMs; does not create VNets or NSGs	Microsoft.Network only partially (NIC, subnet join, LB)
Custom role with AssignableScopes = RG1	Only assignable on RG1 or its resources	Outside the scope it does not appear in the list
Resource moved to another RG or subscription	Assignments **on the resource** are lost (orphaned)	They must be recreated after the move
Deny assignment from a deployment stack	Blocks even if you are Owner	The only way to subtract
User with an assigned role but "Authorization failed"	Wait for propagation, check scope/NotActions/DataActions, PIM not activated, deny assignment	Exam checklist

- **Check access:** Access control (IAM) → **Check access** (what a user / group / MI has at that scope, including inheritance) and **View my access**. In CLI: `az role assignment list --assignee ana@contoso.com --all --include-inherited`; in PowerShell: `Get-AzRoleAssignment -SignInName ana@contoso.com -ExpandPrincipalGroups`.
- **Who can assign roles:** Owner, User Access Administrator, Role Based Access Control Administrator; and a Global Administrator **only after elevating** (section 5).

4. Custom roles

```
{
  "Name": "VM Operator",
  "IsCustom": true,
  "Description": "Start, stop and restart VMs without being able to delete them",
  "Actions": [
    "Microsoft.Compute/virtualMachines/read",
    "Microsoft.Compute/virtualMachines/start/action",
    "Microsoft.Compute/virtualMachines/restart/action",
    "Microsoft.Compute/virtualMachines/deallocate/action",
    "Microsoft.Resources/subscriptions/resourceGroups/read"
  ],
  "NotActions": [],
  "DataActions": [],
  "NotDataActions": [],
  "AssignableScopes": [ "/subscriptions/<sub-id>", "/subscriptions/<sub-id>/resourceGroups/RG1" ]
}
```

- Created in the portal (IAM → Add → **Add custom role**: from scratch, by **cloning** a role or pasting JSON), with `New-AzRoleDefinition -InputFile role.json` or `az role definition create --role-definition role.json`. Update: `Set-AzRoleDefinition` / `az role definition update`. It cannot be deleted while it has assignments.
- **AssignableScopes:** subscriptions, resource groups or **a single** management group; never the root `/`. A role with `DataActions` cannot be assigned at a management group. Wildcards (`Microsoft.Compute/*/read`) are valid.
- To discover operations: `Get-AzProviderOperation "Microsoft.Compute/virtualMachines/*"` or `az provider operation show --namespace Microsoft.Compute`. To start from a built-in role: `Get-AzRoleDefinition "Virtual Machine Contributor"` and export to JSON.
- Typical case: "the team must be able to restart VMs but not delete or create them" → custom role (no built-in fits). "Minimal effort" + a built-in that fits → built-in.

5. Entra ID roles, Azure roles and elevation

	Microsoft Entra ID roles	Azure roles (RBAC)
Scope	Tenant: users, groups, apps, licenses	Resources: management group, subscription, RG, resource
Examples	Global Administrator, User Administrator, Groups Administrator	Owner, Contributor, Reader, UAA
Where	Entra ID → Roles and administrators	Access control (IAM) at each scope
Relationship	**A Global Administrator is not Owner** of anything in Azure	A subscription Owner does not manage users in Entra

- **Elevate access:** Entra ID → Properties → "Access management for Azure resources" = **Yes** (only a Global Administrator can). It gets **User Access Administrator at the root scope** `/`, which lets it assign itself Owner on the Tenant Root Group, see all subscriptions or recover an orphaned subscription. Best practice: **remove the elevation afterwards** (toggle to No and delete the assignment at `/`). It is recorded in the Activity log as `Microsoft.Authorization/elevateAccess/action`.

- Entra roles and Azure roles can be combined in the same person, but they are assigned in different places and neither implies the other.

6. Commands that show up

Task	PowerShell (Az)	Azure CLI
Assign role	`New-AzRoleAssignment -SignInName ana@contoso.com -RoleDefinitionName Contributor -ResourceGroupName RG1` · to a group: `-ObjectId <id> -Scope /subscriptions/<id>`	`az role assignment create --assignee ana@contoso.com --role Contributor --resource-group RG1` · `--scope /subscriptions/<id>`
List	`Get-AzRoleAssignment -ResourceGroupName RG1` · `-SignInName ana@contoso.com -ExpandPrincipalGroups`	`az role assignment list --resource-group RG1 --include-inherited` · `--assignee ana@contoso.com --all`
Remove	`Remove-AzRoleAssignment -SignInName ... -RoleDefinitionName ... -ResourceGroupName RG1`	`az role assignment delete --assignee ... --role ... --resource-group RG1`
View a role	`Get-AzRoleDefinition "Virtual Machine Contributor"` · `(Get-AzRoleDefinition Contributor).NotActions`	`az role definition list --name "Virtual Machine Contributor"`
Custom role	`New-AzRoleDefinition -InputFile role.json` · `Set-AzRoleDefinition -InputFile role.json`	`az role definition create --role-definition role.json` · `az role definition update ...`
Provider operations	`Get-AzProviderOperation "Microsoft.Storage/*"`	`az provider operation show --namespace Microsoft.Storage`
Elevate access (GA)	Portal: Entra ID → Properties → toggle	`az rest --method post --url "/providers/Microsoft.Authorization/elevateAccess?api-version=2016-07-01"`
Remove the elevation	`Remove-AzRoleAssignment -SignInName ga@contoso.com -RoleDefinitionName "User Access Administrator" -Scope "/"`	`az role assignment delete --assignee ga@contoso.com --role "User Access Administrator" --scope "/"`

7. Decision tree

```
What does the wording ask for?
├─ Manage everything except access ..... Contributor
├─ Manage access without touching resources ..... User Access Administrator
├─ Assign roles only, least privilege ..... Role Based Access Control Administrator
├─ Manage VMs without touching the network ..... Virtual Machine Contributor
├─ Read blobs with an Entra identity ..... Storage Blob Data Reader
├─ Rotate storage keys and nothing else ..... Storage Account Key Operator Service Role
├─ View costs without seeing resources ..... Cost Management Reader (or Billing Reader)
├─ Restart VMs but not delete them (no built-in fits) ..... Custom role
├─ Same role across many subscriptions ..... Assign at the management group
├─ Global Admin who cannot see the subscriptions ..... Elevate access → UAA at "/"
├─ User with a role and still "Authorization failed" ..... Propagation / scope / DataActions / deny assignment
└─ Find out what permissions someone has on a resource ..... IAM → Check access
```

8. Signals → answer

Wording	Answer
"least privilege", "manage VMs, cannot modify the virtual network"	Virtual Machine Contributor
"create and manage all resources, cannot grant access"	Contributor
"grant access to others, must not manage resources"	User Access Administrator
"delegate role assignments only"	Role Based Access Control Administrator
"read blob data using Microsoft Entra ID"	Storage Blob Data Reader
"Owner cannot see blobs in the portal"	Switch to key authentication, or add Storage Blob Data Reader
"Reader cannot view the storage account keys"	Correct: listKeys requires Contributor or Storage Account Key Operator
"same permissions on 20 subscriptions, minimal effort"	One assignment at the management group
"user has Reader on subscription and Contributor on RG"	Contributor on the RG, Reader elsewhere
"role assignment missing after moving the resource"	Resource-level assignments do not move: recreate them
"custom role cannot be assigned at management group"	It contains DataActions, or the MG is not in AssignableScopes
"cannot delete the custom role"	Remove its assignments first
"Global Administrator must manage all subscriptions"	Elevate access (toggle) → User Access Administrator at root
"Co-Administrator", "Service Administrator"	Retired classic roles: use Owner / Contributor
"which role assignments does the user have"	IAM → Check access / `az role assignment list --assignee --all`
"sign in to Windows VM with Entra credentials as admin"	Virtual Machine Administrator Login (+ AADLoginForWindows extension)
"temporary / just-in-time Owner on a subscription"	PIM for Azure resources (eligible assignment, P2)

9. Mistakes to avoid

1. Believing that a more restrictive assignment at a lower scope "downgrades" permissions: permissions **add up**; only deny assignments subtract.
2. Confusing Global Administrator with Owner: without elevate access, a GA does not see subscriptions.

3. Granting Owner when Contributor is enough, or Contributor when a service role is enough (VM Contributor, Network Contributor).
4. Expecting Reader or Owner to read blobs with Entra ID: those are DataActions (Storage Blob Data *).
5. Putting the root / or several management groups in a custom role's AssignableScopes.
6. Forgetting that moving a resource loses its resource-level role assignments.
7. Choosing Co-Administrator or Service Administrator: they no longer exist.
8. Trying to delete a custom role with active assignments, or assigning a role with DataActions at a management group.
9. Leaving elevated access enabled after using it.